

CMMC Level 1 System & Information Integrity (SI) Labs — Student Completion Guide

[CMMC Level 1 System & Information Integrity \(SI\) Labs — Student Completion Guide](#)

[Table of Contents](#)

[Before You Begin](#)

[How to Connect to the Lab Environment](#)

[How to Open Your Lab Artifacts](#)

[Understanding Your Pod](#)

[Module 1: Flaw Remediation Foundations](#)

[Module 2: Vulnerability Assessment and Patch Verification](#)

[Module 3: Malware Protection Status](#)

[Module 4: GPO Enforcement and Rogue Developer](#)

[Quick Reference: Where to Find Things](#)

[Tips and Common Mistakes](#)

[Lab Completion Checklist](#)

CMMC Level 1 System & Information Integrity (SI) Labs — Student Completion Guide

This guide provides step-by-step instructions for completing all 12 System & Information Integrity labs. Each lab presents a real-world scenario involving vulnerability management, malware protection, or incident investigation that you must analyze and respond to using artifacts on the domain controller.

Table of Contents

1. [Before You Begin](#)
 2. [How to Connect to the Lab Environment](#)
 3. [How to Open Your Lab Artifacts](#)
 4. [Understanding Your Pod](#)
 5. [Module 1: Flaw Remediation Foundations \(Labs L1.1 – L1.3\)](#)
 6. [Module 2: Vulnerability Assessment and Patch Verification \(Labs L2.1 – L2.3\)](#)
 7. [Module 3: Malware Protection Status \(Labs L3.1 – L3.3\)](#)
 8. [Module 4: GPO Enforcement and Rogue Developer \(Labs L4.1 – L4.3\)](#)
 9. [Quick Reference: Where to Find Things](#)
 10. [Tips and Common Mistakes](#)
 11. [Lab Completion Checklist](#)
-

Before You Begin

What You Need

- Your **Pod number** (your instructor will assign this, e.g., Pod01, Pod05, Pod12)
- Your **Guacamole login credentials** (your instructor will provide your username and password)
- A computer with a web browser (Chrome, Firefox, or Edge) — no special software needed

What You Will Be Doing

In these labs you will analyze **security artifacts** — vulnerability scan reports, patch logs, antivirus inventories, event logs, policy documents, and incident evidence. Unlike the AC labs (which use Active Directory Users and Computers), the SI labs focus on reading, interpreting, and responding to security data. You will fill out worksheets, write reports, and make compliance determinations based on the evidence provided.

CMMC Context

These labs align with **CMMC Level 1 System & Information Integrity (SI)** requirements:

- **SI.L1-3.14.1** — Identify, report, and correct information and information system flaws in a timely manner
 - **SI.L1-3.14.2** — Provide protection from malicious code at appropriate locations within organizational information systems
 - **SI.L1-3.14.4** — Update malicious code protection mechanisms when new releases are available
 - **SI.L1-3.14.5** — Perform periodic scans of the information system and real-time scans of files from external sources
-

How to Connect to the Lab Environment

You will connect to the lab through **Apache Guacamole** — a web-based remote desktop gateway. There is nothing to install; everything runs in your web browser.

Step 1: Open the Guacamole Gateway

1. Open your web browser (Chrome, Firefox, or Edge)
2. Go to: <https://crc.guac.01.tcecur.com/#/>
3. You will see a login screen

Step 2: Log In with Your Student Credentials

1. Enter your **Username** — this matches your pod number:
 - Pod 01 → student01
 - Pod 02 → student02
 - Pod 05 → student05
 - Pod 12 → student12
 - (and so on — the number matches your assigned pod)
2. Enter your **Password** (provided by your instructor)
3. Click **Login**

Step 3: Connect to the Domain Controller

After logging in you will see one pre-configured connection for your pod:

Connection Name	What It Is
PODXX-DC	Domain Controller — use this for all SI labs

This is the only connection you get: every SI lab is done on this desktop.

1. Click on **PODXX-DC** (where XX is your pod number, e.g., **POD03-DC**)

2. The remote desktop session will open directly in your browser — no extra login is needed (credentials are pre-configured)
3. Wait a few seconds for the Windows Server desktop to appear

Tip: To return to the Guacamole home screen (for example, to switch connections), press **Ctrl+Alt+Shift** to open the Guacamole side menu, then click **Home**.

You should now see the Windows Server desktop in your browser.

Step 4: Check Your Lab Progress

You can check your lab verification status in two ways:

Option 1: Click the "Check Your Progress — Pod XX" banner at the top of the Guacamole interface.

Option 2: Go directly to: <https://training.status.tcecure.com/pod/XX> (replace XX with your pod number, e.g., 01)

How to Open Your Lab Artifacts

All SI lab artifacts are stored in a single folder on the domain controller. You will open files in this folder for every lab.

Navigate to Your Artifacts Folder

1. Open **File Explorer** on the server desktop (click the folder icon on the taskbar, or press **Windows + E**)
2. Navigate to: **C:\CyberLab\PodXX\SI-Artifacts** (replace XX with your pod number, e.g., C:\CyberLab\Pod03\SI-Artifacts\)

Alternative method using PowerShell:

1. Press **Windows key + R** to open the Run dialog
2. Type `powershell` and press Enter
3. Run: `explorer "C:\CyberLab\Pod03\SI-Artifacts"` (replace 03 with your pod number)

What You Will See

Your SI-Artifacts folder contains:

- **Policy documents** (files starting with `ACS-POL-`) — reference these for compliance criteria
- **Lab-specific files** (files starting with `SI-MX-LY_`) — the data you will analyze for each lab

- **Lab ready markers** (files starting with `_LAB_READY_`) — these confirm the lab has been seeded

Important: Do NOT delete or modify the original artifact files. When you complete a lab, save your work as a NEW file (instructions are provided in each lab).

Understanding Your Pod

Your instructor assigned you a **Pod number**. Everything you work with is prefixed with your pod number to keep your work separate from other students.

For example, if you are **Pod 03**:

- Your artifact files reference hosts like `P03-ACS-SRV-002`, `P03-WS01`, `P03-DEV-Laptop-04`
- Your artifacts folder is: `C:\CyberLab\Pod03\SI-Artifacts\`
- Your completed work should be saved to the same folder with `_Completed` in the filename

Systems Referenced in SI Labs

The SI labs reference several systems in your pod's simulated environment. These are NOT separate machines you connect to — they are represented in the artifact data files.

System Name	Role	Used In Labs
PXX-WS01	End-user workstation (Windows 11)	M2-L1, M3-L1, M3-L2
PXX-ACS-SRV-002	File server (Windows Server 2022)	M1-L1, M2-L1, M2-L2, M3-L1
PXX-DEV-Laptop-04	Developer workstation (Windows 11)	M1-L1, M2-L1, M3-L1, M4-L2, M4-L3
PXX-Legacy_Server	Legacy application server (Server 2016)	M1-L1, M3-L1, M3-L3
PXX-ACS-DC01	Domain controller	M1-L1, M3-L1
PXX-PRINT-01	Print server (Windows Server 2022)	M3-L1

(Replace PXX with your pod prefix, e.g., P03)

Module 1: Flaw Remediation Foundations

Module 1 focuses on identifying, classifying, and understanding information system flaws. You will learn to distinguish between different types of vulnerabilities and evaluate information sources.

Lab L1.1 — Understanding System Flaws

Scenario: ACS Corp has conducted a security assessment and identified 5 potential flaws across several systems. Your job is to review each finding and classify it as a **Software Flaw**, **Configuration Flaw**, or **Patching Gap**. You will also assess the risk and determine whether each finding should be formally reported for remediation.

Your Task: Read the flaw examples, classify each one, and complete the identification worksheet.

Step-by-Step Instructions:

1. Navigate to your SI-Artifacts folder: **C:\CyberLab\PodXX\SI-Artifacts**
2. Open the file **SI-M1-L1_Flaw_Examples.txt** — this contains 5 security findings
3. Read each finding carefully. Pay attention to:
 - The **System** affected (e.g., PXX-ACS-SRV-002)
 - The **Description** of what is wrong
 - The **Risk** to the organization
4. Also open the policy document **ACS-POL-SI-002_Remediation_Timeline.txt** — this tells you how quickly different severity levels must be fixed
5. Now open the worksheet: **SI-M1-L1_Worksheet.txt**
6. For each of the 5 findings, fill in:
 - **Classification:** Is it a Software Flaw (buggy code), Configuration Flaw (misconfigured setting), or Patching Gap (missing update)?
 - **Risk Level:** Critical, High, Medium, or Low
 - **Risk Explanation:** Why is this a problem? What could an attacker do?
 - **Needs Reporting:** Should a remediation ticket be created? (Yes/No with justification)

How to Classify:

Type	Definition	Example from This Lab
Software Flaw	A bug or vulnerability in the software itself	Adobe Acrobat heap overflow (Finding #2)
Configuration Flaw	The software works correctly but is configured insecurely	SMBv1 enabled (Finding #1), LDAP signing disabled (Finding #3), TLS 1.0 enabled (Finding #5)
Patching Gap	A known patch exists but has not been applied	Failed cumulative update (Finding #4)

1. Save your completed worksheet as: **SI-M1-L1_Completed.txt** in the same folder — write out your full answers, the file must contain at least 100 characters

Why This Matters: CMMC SI.L1-3.14.1 requires organizations to identify system flaws. Before you can fix a problem, you must correctly classify what kind of problem it is — the remediation approach differs for each type.

Lab L1.2 — Active vs Passive Flaw Identification

Scenario: Three different information sources have reported potential vulnerabilities. However, not all sources are equally trustworthy. A CISA government advisory, a Microsoft vendor bulletin, and an anonymous blog post each describe a threat. You need to evaluate the reliability of each source and determine which ones should trigger a formal remediation response.

Your Task: Read three source documents, classify each source's reliability, and determine which are actionable.

Step-by-Step Instructions:

1. Navigate to your SI-Artifacts folder
2. Open and read each of these three source documents:
 - **SI-M1-L2_CISA_Advisory.txt** — A CISA (government) advisory about a critical Windows SMB vulnerability
 - **SI-M1-L2_Vendor_Alert.txt** — A Microsoft security bulletin about an Office vulnerability
 - **SI-M1-L2_Blog_Post.txt** — An anonymous blog post claiming a Windows kernel zero-day exists
3. For each source, consider:
 - **Who** published it? (government agency, software vendor, anonymous blogger)
 - **Is there a CVE assigned?** (official vulnerability identifier)
 - **Is there evidence?** (technical details, patches available, vendor confirmation)
 - **Can you take action?** (is there a specific patch or mitigation to apply?)
4. Open the worksheet: **SI-M1-L2_Worksheet.txt**
5. For each of the 3 sources, fill in:
 - **Source Name:** Who published the information
 - **Source Type:** Government Agency, Software Vendor, Blog/Forum, etc.
 - **Reliability:** Trusted, Untrusted, or Needs Verification
 - **Actionable:** Should this generate a remediation ticket? (Yes/No)
 - **Justification:** Why did you make this determination?
6. Answer the three summary questions at the bottom of the worksheet
7. Save your completed worksheet as: **SI-M1-L2_Completed.txt** — write out your full answers, the file must contain at least 100 characters

Key Concept — Source Reliability:

Source Type	Reliability	Why
Government Agency (CISA)	Trusted	Verified by federal cybersecurity experts, CVE assigned
Software Vendor (Microsoft)	Trusted	Direct knowledge of their own products, patch available
Anonymous Blog	Untrusted	No verification, no CVE, no technical proof

Why This Matters: Organizations receive vulnerability information from many sources. Acting on every rumor wastes resources; ignoring legitimate warnings creates risk. A cybersecurity analyst must evaluate source credibility before initiating remediation.

Lab L1.3 — Window of Exposure Calculation

Scenario: ACS Corp's vulnerability management program tracks 8 findings across the environment. For each finding, you must calculate the "window of exposure" — the time between when a vulnerability was disclosed and when it was (or should have been) remediated. You will compare each window against the company's remediation policy to determine compliance.

Your Task: Analyze the exposure data, calculate compliance, and identify the most critical gaps.

Step-by-Step Instructions:

1. Navigate to your SI-Artifacts folder
2. Open the data file: **SI-M1-L3_Exposure_Data.csv** — this contains 8 vulnerability findings with dates and severity
3. Open the policy reference: **ACS-POL-SI-002_Remediation_Timeline.txt** — review the remediation SLA table in Section 3:

Severity	CVSS Range	Max Window
Critical	9.0 – 10.0	7 days
High	7.0 – 8.9	14 days
Medium	4.0 – 6.9	30 days
Low	0.1 – 3.9	90 days

4. Open the timeline reference: **SI-M1-L3_Timeline_Reference.txt** — this explains how to calculate the exposure window
5. Also reference: **SI-M1-L3_Quick_Reference.txt** — a quick lookup for deadline calculations
6. For each of the 8 findings in the CSV, determine:
 - **Exposure Window:** How many days from Discovery_Date to Remediation_Date (or today if OPEN)
 - **Policy Threshold:** What is the maximum allowed window for this severity?
 - **Compliant:** Is the exposure window within the policy threshold? (YES/NO)
7. Open PowerShell and create a summary report:


```

$date = Get-Date -Format "yyyy-MM-dd"
$summary = @"
SI LAB M1-L3 – Window of Exposure Analysis
Pod: PodXX | Date: $date | Analyst: [Your Name]

FINDING ANALYSIS:
SI-2026-001: Exposure=5d, Max=7d, Status=COMPLIANT
SI-2026-002: [Fill in your analysis]
SI-2026-003: [Fill in your analysis]
SI-2026-004: [Fill in your analysis]
SI-2026-005: [Fill in your analysis]
SI-2026-006: [Fill in your analysis]
SI-2026-007: [Fill in your analysis]
SI-2026-008: [Fill in your analysis]

SUMMARY:
Total Findings: 8
Compliant: [count]
Non-Compliant: [count]
Still Open: [count]

MOST CRITICAL GAP: [Which finding has the worst compliance violation and why?]

RECOMMENDATIONS:
1. [Your recommendation for the most critical issue]
2. [Your recommendation for open findings]
"@
Set-Content "C:\CyberLab\PodXX\SI-Artifacts\SI-M1-L3_Completed.txt" $summary

```

(Replace PodXX with your actual pod, e.g., Pod03)

Hints:

- Finding SI-2026-001 is already marked COMPLIANT (5 days vs 7-day max) — use it as a reference
- Findings with `Remediation_Date = OPEN` are still unresolved — calculate days from `Discovery_Date` to today
- A finding with exposure exceeding the policy max is NON-COMPLIANT even if remediation eventually happened
- Pay special attention to findings that are both OPEN and CRITICAL — these are the highest risk

Why This Matters: The window of exposure is a key compliance metric. CMMC requires timely flaw remediation — tracking how long systems remain vulnerable helps organizations measure their security posture and identify process failures.

Module 2: Vulnerability Assessment and Patch Verification

Module 2 focuses on reading real vulnerability scan output, analyzing patch management data, and creating formal remediation documentation.

Lab L2.1 — Read a Vulnerability Scan Report

Scenario: A weekly Nessus vulnerability scan has been conducted against the file server `PXX-ACS-SRV-002`. The scan found 3 vulnerabilities of varying severity. You need to read the scan report, understand each finding, and determine which ones violate the company's remediation policy.

Your Task: Analyze the Nessus scan report and identify compliance violations.

Step-by-Step Instructions:

1. Navigate to your SI-Artifacts folder
2. Open the scan report: **SI-M2-L1_Nessus_Scan.txt**
3. Read the **Target Host Summary** section — note the hostname, IP, OS, and scan type
4. Review each of the 3 findings:

Finding 1 — Critical (CVSS 9.3):

- What: SMBv1 remote code execution vulnerability
- CVE: CVE-2026-21001
- Age: 365 days open
- Policy max: 7 days for Critical
- **This is a severe compliance violation**

Finding 2 — High (CVSS 7.4):

- What: SSL certificate has expired
- Age: 47 days open
- Policy max: 14 days for High
- **Also a compliance violation**

Finding 3 — Medium (CVSS 5.6):

- What: Missing Spectre/Meltdown mitigations
- Age: 182 days open
- Policy max: 30 days for Medium
- **Also a compliance violation**

5. Also open the remediation policy: **ACS-POL-SI-002_Remediation_Timeline.txt** — verify the SLA thresholds match your analysis

6. Open PowerShell and create your analysis:

```
$date = Get-Date -Format "yyyy-MM-dd"
$analysis = @"
SI LAB M2-L1 – Nessus Scan Analysis
Pod: PodXX | Date: $date | Analyst: [Your Name]

HOST: PXX-ACS-SRV-002 (Windows Server 2022)
SCAN DATE: [from report]

FINDING 1: CVE-2026-21001 – SMBv1 RCE
Severity: Critical (CVSS 9.3)
Age: 365 days | Max Allowed: 7 days
Status: NON-COMPLIANT (exceeded by 358 days)
Recommended Action: [Your recommendation]

FINDING 2: Expired SSL Certificate
Severity: High (CVSS 7.4)
Age: 47 days | Max Allowed: 14 days
Status: NON-COMPLIANT (exceeded by 33 days)
Recommended Action: [Your recommendation]

FINDING 3: Missing Speculative Execution Mitigations
Severity: Medium (CVSS 5.6)
Age: 182 days | Max Allowed: 30 days
Status: NON-COMPLIANT (exceeded by 152 days)
Recommended Action: [Your recommendation]

OVERALL COMPLIANCE: NON-COMPLIANT (3/3 findings overdue)
PRIORITY ACTION: [Which finding should be fixed first and why?]
"@
Set-Content "C:\CyberLab\PodXX\SI-Artifacts\SI-M2-L1_Completed.txt" $analysis
```

Why This Matters: Vulnerability scanners like Nessus are the primary tool for automated flaw identification. Every cybersecurity professional must be able to read scan output, understand severity scoring, and determine which findings need immediate attention.

Lab L2.2 — Patch Verification

Scenario: The IT team claims they have been patching PXX-ACS-SRV-002 regularly. You have been given the Windows Update patch history log and the event log from failed updates. Your job is to determine whether the patching program is actually working — paying close attention to the difference between "attempted" and "successful" patching.

Your Task: Analyze the patch log and event evidence to determine the true patch status.

Step-by-Step Instructions:

1. Navigate to your SI-Artifacts folder
2. Open the patch history: **SI-M2-L2_Patch_History.csv**

3. Review each row in the CSV. Note:
 - **Defender definition updates** (KB5035100): All show Result = Success — antimalware signatures are being updated correctly
 - **Cumulative security updates** (KB5035849, KB5034441, KB5033900): All show Result = Failed with various error codes
 - **The pattern:** Small signature updates succeed, but the critical security cumulative update has failed **4 consecutive times** over 3 months
4. Open the event log evidence: **SI-M2-L2_Event_Log.txt**
5. Review the Windows Update error events:
 - Event ID 20 (Error) — Installation failures with error 0x80070643
 - Event ID 19 (Information) — Successful Defender updates
 - Note the **Key Observations** section at the bottom of the file
6. Answer these questions in your report:
 - Is the server patched? (No — cumulative updates are failing)
 - Is the vulnerability addressed by KB5035849 remediated? (No — failed install does not equal remediation)
 - Does the presence of successful Defender updates prove the system is secure? (No — different update types)
7. Create your analysis using PowerShell:

```

$date = Get-Date -Format "yyyy-MM-dd"
$report = @"
SI LAB M2-L2 – Patch Verification Analysis
Pod: PodXX | Date: $date | Analyst: [Your Name]

HOST: PXX-ACS-SRV-002

PATCH HISTORY SUMMARY:
- Defender Definition Updates: [count] attempted, [count] successful
- Cumulative Security Updates: [count] attempted, [count] successful
- .NET Updates: [count] attempted, [count] successful

FAILED PATCHES:
1. [Date] – KB5035849 – Error: [code] – [reason]
2. [Date] – KB5035849 – Error: [code] – [reason]
3. [Date] – KB5034441 – Error: [code] – [reason]
4. [Date] – KB5033900 – Error: [code] – [reason]

KEY FINDING: [Explain why the system is NOT compliant despite
showing patch activity]

ROOT CAUSE: [What is causing the patch failures?]

RECOMMENDED ACTIONS:
1. [Your first recommendation]
2. [Your second recommendation]
3. [Your third recommendation]
"@
Set-Content "C:\CyberLab\PodXX\SI-Artifacts\SI-M2-L2_Completed.txt" $report

```

Key Concept: A failed patch attempt does NOT satisfy the remediation requirement. Per the ACS remediation policy (Section 6): "An attempted patch that FAILS to install does NOT satisfy the remediation requirement. The vulnerability remains OPEN until a successful installation is confirmed via re-scan."

Why This Matters: Many organizations mistakenly believe that having a patching process means they are patched. Verification is critical — you must confirm patches actually installed successfully, not just that an attempt was made.

Lab L2.3 — Remediation Reporting

Scenario: Now that you have identified vulnerabilities (L2.1) and verified that patches are failing (L2.2), you must create formal documentation: a **Vulnerability Finding Report** and a **Remediation Ticket** for the most critical open finding.

Your Task: Complete the vulnerability report form and create a remediation ticket.

Step-by-Step Instructions:

1. Navigate to your SI-Artifacts folder
2. Open the blank report form: **SI-M2-L3_Report_Form.txt**
3. Using the Nessus scan from L2.1 (reference copy at **SI-M2-L3_Nessus_Reference.txt**), fill in the report for the **Critical** finding (CVE-2026-21001):
 - **Section 1 — Finding Identification:**
 - Finding ID: SI-2026-001
 - Date Discovered: (from the Nessus report "First Discovered" field)
 - Discovered By: Automated Scan
 - Host Affected: PXX-ACS-SRV-002
 - **Section 2 — Vulnerability Details:**
 - CVE: CVE-2026-21001
 - CVSS Score: 9.3
 - Severity: Critical
 - Title and description from the Nessus finding
 - **Section 3 — Risk Assessment:**
 - Exploitability: Network (Remote)
 - User Interaction: None Required
 - Privileges Required: None
 - **Section 4 — Remediation Plan:**
 - Type: Patch/Update
 - Specific Action: Apply KB5035849
 - Deadline: (calculate from the policy — 7 days from discovery for Critical)
 - **Section 5 — Routing:**
 - Route to IT Administrator (for patching) AND CISO (Critical finding)
 - **Section 6 — Verification:**
 - Method: Re-scan after patch installation

4. Save the completed report as: **SI-M2-L3_Completed.txt** (this exact name is required)
5. Now open the ticket template: **SI-M2-L3_Ticket_Template.txt**
6. Fill in the remediation ticket:
 - Reference Finding: SI-2026-001
 - Affected System: PXX-ACS-SRV-002
 - CVE and CVSS from the report
 - Due Date: calculate using policy reference at **SI-M2-L3_Timeline_Reference.txt**
 - Remediation Steps: List the specific actions IT must take (apply patch, verify, re-scan)
7. Save the completed ticket as: **SI-M2-L3_Remediation_Ticket.txt** (this exact name is required, and it must be at least 50 characters of content)

Why This Matters: Formal documentation is required by CMMC for all identified vulnerabilities. A vulnerability that is not documented cannot be tracked, assigned, or verified as remediated. The report creates the compliance paper trail.

Module 3: Malware Protection Status

Module 3 focuses on verifying that antivirus protection is properly deployed, configured, and maintained across all systems. You will audit endpoint coverage, scan schedules, and definition currency.

Lab L3.1 — Verify AV Installation and Coverage

Scenario: Company policy requires that ALL endpoints have antivirus software installed with real-time protection enabled. You have been given an inventory of all systems and their AV status. Some systems may be missing protection entirely or have outdated configurations.

Your Task: Review the AV inventory, identify non-compliant systems, and document the gaps.

Step-by-Step Instructions:

1. Navigate to your SI-Artifacts folder
2. Open the AV inventory: **SI-M3-L1_AV_Inventory.csv**
3. Review each system's status. Look for:
 - **AV_Product = NONE** — No antivirus installed at all
 - **Real_Time_Protection = Disabled or N/A** — Protection not active
 - **Old Definition_Date** — Signatures severely outdated
 - **Status = NON-COMPLIANT** — Systems that fail the policy check
4. Open the endpoint status report: **SI-M3-L1_Endpoint_Status.csv**
5. This report shows detailed compliance checks per system. Look for rows where **Compliant = FAIL**:
 - Which systems are failing?

- What specific requirements are they failing? (AV Installation, RTP, Definition Currency, Full Scan)
- 6. Open the policy: **ACS-POL-SI-003_Malware_Protection.txt** — review Sections 3.1 through 3.4 to understand what is required
- 7. Create your compliance report using PowerShell:

```
$date = Get-Date -Format "yyyy-MM-dd"
$report = @"
SI LAB M3-L1 – AV Coverage Audit
Pod: PodXX | Date: $date | Analyst: [Your Name]

ENDPOINT INVENTORY:
Total Systems: 6
Compliant: [count]
Non-Compliant: [count]

NON-COMPLIANT SYSTEMS:

System 1: PXX-DEV-Laptop-04
  Issue: [Describe what is wrong]
  Policy Violation: [Which policy section is violated?]
  Risk: [What is the security risk?]
  Recommended Action: [How to fix]

System 2: PXX-Legacy_Server
  Issue: [Describe what is wrong]
  Policy Violation: [Which policy section is violated?]
  Risk: [What is the security risk?]
  Recommended Action: [How to fix]

COMPLIANT SYSTEMS: [List the systems that pass all checks]

OVERALL COMPLIANCE RATE: [X/6 systems compliant = X%]
"@
Set-Content "C:\CyberLab\PodXX\SI-Artifacts\SI-M3-L1_Completed.txt" $report
```

Hints:

- PXX-DEV-Laptop-04 has **NO** antivirus installed at all — this is a critical gap
- PXX-Legacy_Server has Defender installed but with **extremely old** definitions (2019) and has not been scanned since November 2025
- The other 4 systems (PXX-WS01, PXX-ACS-SRV-002, PXX-PRINT-01, PXX-ACS-DC01) are compliant

Why This Matters: CMMC SI.L1-3.14.2 requires malware protection at all appropriate locations. A single unprotected endpoint can be the entry point for a network-wide compromise. Regular coverage audits ensure no gaps exist.

Lab L3.2 — Review Malware Scan Logs

Scenario: ACS Corp policy requires weekly full scans on all protected endpoints. You have been given scan history records and Windows Defender event logs. Your job is to verify that scans are running on schedule and producing the expected results.

Your Task: Analyze the scan history and event logs to verify scan compliance.

Step-by-Step Instructions:

1. Navigate to your SI-Artifacts folder
2. Open the scan history: **SI-M3-L2_Scan_History.csv**
3. For each system, check:
 - Is there a **weekly** full scan occurring? (Policy requires at minimum weekly)
 - Are scans completing successfully? (Result should be "Clean" — no threats found is expected for well-maintained systems)
 - Is every system being scanned? (Look for systems with N/A — these have no scans at all)
4. Open the event log: **SI-M3-L2_Event_Log.txt**
5. Review the Defender events:
 - **Event ID 1000** — Scan started (verify scheduled time matches policy)
 - **Event ID 1001** — Scan completed (note items scanned and results)
 - **Event ID 2000** — Definitions updated (verify regular updates)
6. Verify the scan cadence:
 - PXX-WS01: Scans on Jun 1, May 25, May 18, May 11, May 4 — **weekly, COMPLIANT**
 - PXX-ACS-SRV-002: Scans on Jun 1, May 25, May 18 — **weekly, COMPLIANT**
 - PXX-Legacy_Server: Last scan Nov 15, 2025 — **no recent scans, NON-COMPLIANT**
 - PXX-DEV-Laptop-04: No AV installed — **no scans possible, NON-COMPLIANT**
7. Create your compliance report:


```

$date = Get-Date -Format "yyyy-MM-dd"
$report = @"
SI LAB M3-L2 – Scan Log Analysis
Pod: PodXX | Date: $date | Analyst: [Your Name]

SCAN COMPLIANCE BY SYSTEM:

PXX-WS01: [COMPLIANT/NON-COMPLIANT]
  Last Scan: [date]
  Frequency: [weekly/monthly/none]
  Threats Found: [count]
  Definition Updates: [regular/irregular/none]

PXX-ACS-SRV-002: [COMPLIANT/NON-COMPLIANT]
  Last Scan: [date]
  Frequency: [weekly/monthly/none]

PXX-Legacy_Server: [COMPLIANT/NON-COMPLIANT]
  Last Scan: [date]
  Issue: [Explain the gap]

PXX-DEV-Laptop-04: [COMPLIANT/NON-COMPLIANT]
  Issue: [Explain why scans cannot run]

EVENT LOG OBSERVATIONS:
- Scan schedule: [What time do scans run?]
- Definition update frequency: [How often are definitions updated?]
- Any anomalies? [Anything unusual in the logs?]

OVERALL: [X/4 systems scan-compliant]
"@
Set-Content "C:\CyberLab\PodXX\SI-Artifacts\SI-M3-L2_Completed.txt" $report

```

Why This Matters: CMMC SI.L1-3.14.5 requires periodic scans. Having antivirus installed is not enough — it must actively scan the system on a regular schedule. Inactive or non-functional AV provides a false sense of security.

Lab L3.3 — Antivirus Definition Currency Check

Scenario: Antivirus software is only as good as its latest definitions. Company policy requires definitions to be updated within 7 days. Systems with definitions older than 30 days must be isolated from the network. You have a definition status report showing the current state across all endpoints.

Your Task: Identify systems with outdated definitions and determine the compliance impact.

Step-by-Step Instructions:

1. Navigate to your SI-Artifacts folder
2. Open the definition status report: **SI-M3-L3_Definition_Status.csv**

3. For each system, check:
 - **Definition_Date:** When were the definitions last updated?
 - **Days_Since_Update:** How many days since the last update?
 - **Max_Allowed_Days:** Policy allows 7 days maximum
 - **Compliant:** YES or NO
4. Identify the problem systems:
 - PXX-Legacy_Server: Definitions from **2019-03-22** — over 2,600 days old! This system's AV is essentially useless
 - PXX-DEV-Laptop-04: No AV installed — cannot have definitions
5. Also reference the coverage inventory: **SI-M3-L3_Coverage_Reference.csv** — cross-reference with the definition data
6. Review the policy: **ACS-POL-SI-003_Malware_Protection.txt** — specifically Section 3.3 (Definition Updates):
 - Definitions > 7 days old = NON-COMPLIANT
 - Definitions > 30 days old = system must be **isolated from the network**
7. Create your analysis:

```

$date = Get-Date -Format "yyyy-MM-dd"
$report = @"
SI LAB M3-L3 – Definition Currency Audit
Pod: PodXX | Date: $date | Analyst: [Your Name]

DEFINITION STATUS:

[For each of the 6 systems, list:]
PXX-[hostname]:
  Definition Version: [version]
  Last Updated: [date]
  Days Since Update: [number]
  Policy Max: 7 days
  Status: [COMPLIANT / NON-COMPLIANT]
  Action Required: [None / Update / Isolate / Install AV]

CRITICAL FINDINGS:

1. PXX-Legacy_Server: Definitions are [X] days old
  - Per policy Section 3.3: Systems > 30 days old must be ISOLATED
  - This system should be immediately disconnected from the network
  - Recommended: Update definitions, run full scan, then reconnect

2. PXX-DEV-Laptop-04: No antivirus installed
  - Cannot have definitions without AV
  - Recommended: Install Microsoft Defender immediately

COMPLIANCE SUMMARY: [X/6 systems compliant]
"@
Set-Content "C:\CyberLab\PodXX\SI-Artifacts\SI-M3-L3_Completed.txt" $report

```

Why This Matters: CMMC SI.L1-3.14.4 requires updating malicious code protection mechanisms when new releases are available. Outdated definitions mean the AV cannot

detect recent threats — a system running 2019 definitions cannot protect against 2026 malware.

Module 4: GPO Enforcement and Rogue Developer

Module 4 focuses on how security policies are enforced through Group Policy, and what happens when a user circumvents those policies. You will investigate a real incident scenario involving a developer who disabled endpoint protection.

Lab L4.1 — Defender GPO Review

Scenario: ACS Corp uses Group Policy to enforce Windows Defender settings across all endpoints. A Group Policy Object (GPO) named `PXX-SI-Defender-Policy` has been created and linked to your pod's OU. Your job is to review the GPO settings and verify they enforce the requirements from the Malware Protection Policy.

Your Task: Review the GPO report and verify all required settings are configured.

Step-by-Step Instructions:

1. Navigate to your SI-Artifacts folder
2. Open the GPO report: **SI-M4-L1_GPO_Report.txt**
3. Compare each GPO setting against the policy requirements in **ACS-POL-SI-003_Malware_Protection.txt**:

Check 1 — Defender Cannot Be Disabled:

- GPO Setting: "Turn off Microsoft Defender Antivirus" = **Disabled**
- This means: Defender CANNOT be turned off — correct!

Check 2 — Real-Time Protection Enforced:

- "Turn off real-time protection" = **Disabled** (RTP cannot be turned off)
- "Monitor file and program activity" = **Enabled**
- "Scan all downloaded files and attachments" = **Enabled**
- "Turn on behavior monitoring" = **Enabled**
- All correct!

Check 3 — Definition Update Schedule:

- Definitions considered out of date after = **7 days** (matches policy)
- Check interval = **1 hour** (aggressive, good)
- Check on startup = **Enabled**
- All correct!

Check 4 — Scan Schedule:

- Scan type = **Full Scan**
- Schedule = **Every day at 02:00 AM**
- This exceeds the weekly minimum — correct!

Check 5 — Tamper Protection (THE GAP):

- The GPO says: NOT CONFIGURED IN GPO
- The note explains: Tamper Protection is managed via Microsoft Security Center, not GPO
- **This is the finding** — there is no GPO enforcement for tamper protection
- Students must document this gap and explain how to verify Tamper Protection status

4. Complete the checklist at the bottom of the GPO report

5. Create your review using PowerShell:

```

$date = Get-Date -Format "yyyy-MM-dd"
$review = @"
SI LAB M4-L1 – GPO Compliance Review
Pod: PodXX | Date: $date | Analyst: [Your Name]

GPO NAME: PXX-SI-Defender-Policy
LINKED TO: OU=PodXX,OU=Students,DC=acs-p01,DC=local

SETTING REVIEW:

1. Turn off Defender = Disabled
   Policy Requirement: Section 3.1 - AV must be installed
   Status: COMPLIANT

2. Real-Time Protection = Active
   Policy Requirement: Section 3.2 - RTP must be enabled
   Status: COMPLIANT

3. Definition Updates = 7-day max, hourly checks
   Policy Requirement: Section 3.3 - Update within 7 days
   Status: COMPLIANT

4. Full Scan Schedule = Daily at 02:00
   Policy Requirement: Section 3.4 - Weekly minimum
   Status: COMPLIANT (exceeds requirement)

5. Tamper Protection = NOT CONFIGURED IN GPO
   Policy Requirement: Section 3.5 - Must be enabled
   Status: GAP IDENTIFIED
   Finding: Tamper Protection cannot be enforced via GPO.
   Must be verified manually using:
       Get-MpPreference | Select IsTamperProtected
   Recommendation: [Your recommendation]

OVERALL: 4/5 settings compliant, 1 gap identified
"@
Set-Content "C:\CyberLab\PodXX\SI-Artifacts\SI-M4-L1_Completed.txt" $review

```

Why This Matters: Group Policy is the primary mechanism for enforcing security settings at scale. If a setting is not in the GPO, individual users can change it. Understanding what GPO can and cannot enforce is critical for security architecture.

Lab L4.2 — Event Viewer: Disabled Protection Detection

Scenario: Security monitoring has detected a series of concerning events on the developer workstation `PXX-DEV-Laptop-04`. Windows Defender was disabled, real-time protection was turned off, and scanning was stopped — all by the same user account. You need to analyze the security event log to reconstruct what happened.

Your Task: Read the security events and create a timeline of the incident.

Step-by-Step Instructions:

1. Navigate to your SI-Artifacts folder
2. Open the event log: **SI-M4-L2_Security_Events.txt**
3. Read each event in chronological order and note:

Event Timeline:

Time	Event ID	What Happened
09:14:22	5007	PXX-d.chen changed DisableAntiSpyware from 0 to 1 (Defender OFF)
09:14:23	5001	Real-time protection disabled — service stopped
09:15:01	5007	PXX-d.chen changed DisableRealtimeMonitoring from 0 to 1 (RTP OFF)
09:15:02	5010	Malware scanning disabled entirely
09:22:45	5007	PXX-d.chen added exclusion path C:\DevBuilds
(~23 hour gap — NO protection)		
08:00:01 (next day)	5007	GPO refresh restored DisableAntiSpyware to 0 (Defender back ON)
08:00:05	1000	Quick scan triggered by protection re-enable

4. Review the policy: **ACS-POL-SI-003_Malware_Protection.txt** — specifically Sections 4.1 (Prohibited Actions) and 6 (Non-Compliance Consequences)
5. Answer these questions in your report:
 - Who disabled protection? (PXX-d.chen)
 - What exactly did they disable? (Defender, RTP, scanning, added exclusion)
 - How long was protection off? (~23 hours)
 - What restored protection? (GPO refresh the next morning)
 - Which policy sections were violated? (Section 4.1 and 4.2)
6. Create your incident analysis:

```

$date = Get-Date -Format "yyyy-MM-dd"
$analysis = @"
SI LAB M4-L2 – Security Event Analysis
Pod: PodXX | Date: $date | Analyst: [Your Name]

INCIDENT TIMELINE:
[List each event with timestamp, Event ID, and description]

KEY FINDINGS:
1. User PXX-d.chen intentionally disabled endpoint protection
2. Protection was off for approximately [X] hours
3. During unprotected period, user had internet access
4. Unauthorized exclusion added for C:\DevBuilds
5. Protection was only restored by automated GPO refresh

POLICY VIOLATIONS:
- Section 4.1: Users SHALL NOT disable antivirus
- Section 4.2: Developers SHALL NOT disable Defender
- Section 5: Exclusions require IT Security approval

CRITICAL EVENT IDs TO MONITOR:
- 5001: Real-time protection disabled
- 5007: Defender configuration changed
- 5010: Scanning disabled

RISK ASSESSMENT:
[What could have happened during the 23-hour unprotected window?]
"@
Set-Content "C:\CyberLab\PodXX\SI-Artifacts\SI-M4-L2_Completed.txt" $analysis

```

Why This Matters: Security event monitoring is essential for detecting policy violations in real time. The Event IDs 5001, 5007, and 5010 are the key indicators that endpoint protection has been tampered with. A SIEM should alert on these events immediately — waiting for GPO refresh (as happened here) leaves a dangerous window of exposure.

Lab L4.3 — Rogue Developer Investigation

Scenario: This is the full incident investigation combining everything from Labs L4.1 and L4.2. Developer David Chen (PXX-d.chen) disabled Windows Defender on his workstation to speed up his software builds. You have event logs, an interview transcript, and the exclusion request form. You must conduct a complete investigation: review the evidence, assess the damage, determine the correct response, and fill out the exclusion form showing what David SHOULD have done.

Your Task: Complete a full incident investigation with evidence review, interview analysis, and corrective action.

Step-by-Step Instructions:

1. Navigate to your SI-Artifacts folder

2. You will work with 5 files for this lab:

- **SI-M4-L3_Event_Evidence.txt** — The security event log (same data as L4.2)
- **SI-M4-L3_Interview_Transcript.txt** — David Chen's interview with IT Security
- **SI-M4-L3_Exclusion_Form.txt** — Blank exclusion request form
- **ACS-POL-SI-003_Malware_Protection.txt** — The malware protection policy
- **SI-M4-L3_GPO_Reference.txt** — The GPO settings (same as L4.1)

3. Step A — Review the Event Evidence:

- Open **SI-M4-L3_Event_Evidence.txt**
- Confirm the timeline from L4.2 — protection was disabled for ~23 hours
- Note that an unauthorized exclusion for `C:\DevBuilds` was also added

4. Step B — Read the Interview Transcript:

- Open **SI-M4-L3_Interview_Transcript.txt**
- Key admissions from David Chen:
 - He **intentionally** disabled Defender (not accidental)
 - His reason: build times went from 3 minutes to 20 minutes with Defender active
 - He did **NOT** submit an exclusion request — he knew the process existed but bypassed it
 - He assumed local admin rights meant he could manage his own workstation
 - He was browsing the internet and downloading packages during the unprotected period
 - He acknowledges the correct approach would have been to submit the exclusion form

5. Step C — Fill Out the Exclusion Form (What David SHOULD Have Done):

- Open **SI-M4-L3_Exclusion_Form.txt**
- Fill it out as if you are David Chen submitting a **proper** exclusion request:
 - Requestor: David Chen (PXX-d.chen)
 - Department: Software Development
 - Workstation: PXX-DEV-Laptop-04
 - Exclusion Type: Folder
 - Specific Path: `C:\DevBuilds`
 - Business Reason: Compiler output files trigger Defender scans during builds, increasing build times from 3 to 20 minutes
 - Duration: Project-based (provide an end date)
 - Risk Acknowledgement: Check all boxes
- Save as: **SI-M4-L3_Exclusion_Completed.txt**

6. Step D — Write the Investigation Report:


```

$date = Get-Date -Format "yyyy-MM-dd"
$report = @"
SI LAB M4-L3 – Incident Investigation Report
Pod: PodXX | Date: $date | Analyst: [Your Name]

INCIDENT SUMMARY:
On 2026-05-15, developer PXX-d.chen intentionally disabled Windows
Defender on PXX-DEV-Laptop-04 to improve build performance. Protection
remained off for approximately 23 hours until GPO refresh restored it.

EVIDENCE REVIEWED:
1. Windows Defender event log (Event IDs: 5001, 5007, 5010)
2. Interview transcript with PXX-d.chen
3. ACS-POL-SI-003 Malware Protection Policy
4. GPO configuration for PXX-SI-Defender-Policy

TIMELINE:
[List the complete timeline from event log]

INTERVIEW FINDINGS:
- Action was intentional, not accidental
- Motivation: Build performance (legitimate concern, wrong approach)
- User bypassed established exclusion request process
- User had internet access during unprotected period

POLICY VIOLATIONS:
1. Section 4.1: Disabled antivirus protection
2. Section 4.2: Developer disabled Defender for build performance
3. Section 5: Added exclusion without IT Security approval
4. Section 3.5: Tamper protection was circumvented

RISK EXPOSURE:
- 23 hours without malware protection
- Active internet browsing and package downloads during exposure
- Unknown files downloaded without scanning
- Potential malware could have been introduced to corporate network

CORRECTIVE ACTIONS:
1. [What should happen to the user per policy Section 6?]
2. [What technical controls should be added?]
3. [What process improvements are needed?]
4. [Should the exclusion for C:\DevBuilds be approved properly?]

LESSONS LEARNED:
[What should the organization change to prevent this from happening again?]
"@
Set-Content "C:\CyberLab\PodXX\SI-Artifacts\SI-M4-L3_Completed.txt" $report

```

Why This Matters: This lab brings together everything from Module 4: GPO enforcement, event detection, incident investigation, and policy compliance. In the real world, insider threats from well-meaning employees (like David disabling AV for convenience) are one of the most common security incidents. The proper response combines technical controls (GPO

enforcement, tamper protection) with process controls (exclusion request forms, user education).

Quick Reference: Where to Find Things

What You Need	Where to Find It
Your lab artifacts folder	C:\CyberLab\PodXX\SI-Artifacts\
Remediation timeline policy	ACS-POL-SI-002_Remediation_Timeline.txt
Malware protection policy	ACS-POL-SI-003_Malware_Protection.txt
Flaw examples for classification	SI-M1-L1_Flaw_Examples.txt
Source documents for evaluation	SI-M1-L2_CISA_Advisory.txt, SI-M1-L2_Vendor_Alert.txt, SI-M1-L2_Blog_Post.txt
Exposure calculation data	SI-M1-L3_Exposure_Data.csv
Nessus vulnerability scan	SI-M2-L1_Nessus_Scan.txt
Patch history log	SI-M2-L2_Patch_History.csv
AV coverage inventory	SI-M3-L1_AV_Inventory.csv
Scan history	SI-M3-L2_Scan_History.csv
Definition status report	SI-M3-L3_Definition_Status.csv
GPO report	SI-M4-L1_GPO_Report.txt
Rogue developer events	SI-M4-L2_Security_Events.txt
Interview transcript	SI-M4-L3_Interview_Transcript.txt
Exclusion request form	SI-M4-L3_Exclusion_Form.txt
Open PowerShell	Start menu → type "PowerShell" → click Windows PowerShell

Tips and Common Mistakes

Do's

- **Always read the policy documents first** — they tell you the compliance criteria you need to evaluate against
- **Double-check your pod number** before saving files — use your PXX prefix in all file references
- **Cross-reference between files** — many labs require you to look at multiple artifacts together

- **Show your reasoning** — don't just write "NON-COMPLIANT"; explain WHY and cite the specific policy section
- **Work through the labs in order** — Module 1 teaches concepts used in Modules 2, 3, and 4
- **Save your completed work** with `_Completed` in the filename so you can distinguish it from the original artifacts

Don'ts

- **Don't modify the original artifact files** — always create new files for your answers
- **Don't guess at compliance status** — calculate exposure windows, check dates, reference the policy thresholds
- **Don't skip the summary/recommendations** — identifying the problem is only half the job; recommending the fix is the other half
- **Don't assume "attempted patch" means "patched"** — a failed installation leaves the vulnerability OPEN
- **Don't treat all information sources equally** — a CISA advisory and an anonymous blog post have very different reliability levels
- **Don't forget to check definitions AND scan schedules** — both are required for AV compliance

If Something Goes Wrong

- If you can't find your artifacts folder, verify the path: `C:\CyberLab\PodXX\SI-Artifacts\` (replace XX with your pod number)
- If a file appears empty or missing, tell your instructor — the lab may need to be re-seeded
- If PowerShell gives a path error, make sure you replaced `PodXX` and `PXX` with your actual pod number
- If you need to start a lab over, your original artifact files are unchanged — just delete your `_Completed` file and try again

Lab Completion Checklist

Use this checklist to track your progress:

Lab	Task	Done?
L1.1	Classify 5 system flaws and complete the identification worksheet	☐
L1.2	Evaluate 3 vulnerability sources and complete the classification worksheet	☐
L1.3	Calculate exposure windows for 8 findings and write analysis report	☐
L2.1	Analyze Nessus scan report and identify compliance violations	☐
L2.2	Review patch history and determine true patch status	☐

Lab	Task	Done?
L2.3	Complete vulnerability report form and remediation ticket	☐
L3.1	Audit AV coverage across 6 endpoints and identify gaps	☐
L3.2	Verify scan schedules and log analysis across all systems	☐
L3.3	Check definition currency and identify systems requiring isolation	☐
L4.1	Review GPO settings and identify the Tamper Protection gap	☐
L4.2	Reconstruct incident timeline from Defender event log	☐
L4.3	Complete full rogue developer investigation with exclusion form	☐